



Universidad Politécnica de San Luis Potosí

Ingeniería en Tecnologías de la Información

PR02

El eslabón más débil:
diseño ético de una campaña de ingeniería social

Alumno:

Erik De La Rosa Rodríguez

Matrícula: 177700

Asignatura:

CNG V: Seguridad Informática

Docente:

Mtro. Servando López Contreras

San Luis Potosí, S.L.P.
6 de marzo de 2026

Índice

Introducción	2
1. Objetivo de la investigación	2
2. Metodología	2
3. Fundamentación técnica: métricas en ciberseguridad	3
3.1. Click Rate	3
3.2. Reporting Rate	3
3.3. Risk Score	3
4. Análisis de plataformas	4
4.1. Hoxhunt	4
4.2. Proofpoint	4
4.3. KnowBe4	4
4.4. Cofense	4
4.5. Phished	4
4.6. NINJIO	4
4.7. Mimecast	5
4.8. Infosec IQ	5
5. Tabla comparativa	6
6. Diagrama del flujo de una simulación de phishing	7
7. Conclusiones	8
8. Referencias	8

Introducción

La ingeniería social representa una de las amenazas más relevantes dentro del panorama actual de la ciberseguridad. A diferencia de otros ataques informáticos que explotan vulnerabilidades técnicas, esta categoría de ataque se enfoca en manipular el comportamiento humano para obtener acceso a información sensible, credenciales o recursos críticos.

Entre estas técnicas, el phishing continúa siendo una de las más utilizadas, debido a que aprovecha factores psicológicos como la urgencia, la autoridad aparente y la confianza del usuario (NIST, 2023; SANS Institute, 2023). Con el paso del tiempo, los ataques han evolucionado desde campañas masivas y genéricas hasta estrategias dirigidas como el *spear phishing* y el *Business Email Compromise* (BEC), apoyándose incluso en información pública obtenida mediante *Open Source Intelligence* (OSINT).

Este contexto demuestra que las organizaciones no pueden depender únicamente de controles tecnológicos. La capacitación y concientización de los usuarios se ha convertido en un componente esencial para reducir el riesgo humano dentro de los sistemas de información.

1. Objetivo de la investigación

Objetivo del estudio

Analizar y comparar plataformas profesionales de simulación de phishing y concientización en ciberseguridad, con el fin de comprender sus metodologías, métricas de evaluación y enfoques éticos para el entrenamiento de usuarios dentro de entornos corporativos.

2. Metodología

Se realizó una investigación documental y comparativa basada en la revisión de características, capacidades y enfoques declarados por ocho plataformas especializadas en *Security Awareness Training*. La comparación se sustentó en criterios de desempeño utilizados por la industria para evaluar programas efectivos de concientización y entrenamiento en seguridad (Gartner, 2022).

Para el análisis se consideraron los siguientes criterios:

- **Enfoque analítico:** tecnología o método utilizado para diseñar simulaciones, como inteligencia artificial, inteligencia de amenazas u OSINT.

- **Capacidad técnica:** nivel de realismo, variedad y personalización de las campañas de phishing.
- **Integración y ética:** relación entre efectividad del entrenamiento y respeto al usuario dentro del entorno corporativo.
- **Limitaciones:** restricciones funcionales, complejidad operativa, rigidez del sistema o costo.

3. Fundamentación técnica: métricas en ciberseguridad

Las plataformas de simulación de phishing permiten medir el **riesgo humano** dentro de una organización mediante indicadores específicos. Estas métricas permiten evaluar el comportamiento del usuario, justificar la inversión en programas de concientización y detectar áreas de mejora dentro de la cultura de seguridad organizacional (SANS Institute, 2023).

3.1. Click Rate

Es el porcentaje de usuarios que hacen clic en un enlace malicioso o interactúan con un archivo adjunto dentro de una simulación. Esta métrica permite estimar la vulnerabilidad inicial frente a ataques de ingeniería social.

3.2. Reporting Rate

Corresponde a la proporción de usuarios que reportan de forma proactiva un correo sospechoso al equipo de TI o seguridad. Un alto *Reporting Rate* refleja una cultura organizacional más madura y participativa.

3.3. Risk Score

Es un indicador compuesto que agrupa distintos comportamientos del usuario, como clics, reportes, reincidencia e interacción con contenidos de entrenamiento, con el objetivo de estimar el nivel de riesgo por usuario, grupo o departamento.

4. Análisis de plataformas

A continuación, se presenta una síntesis descriptiva de ocho plataformas relevantes dentro del mercado de simulación de phishing y concientización en ciberseguridad.

4.1. Hoxhunt

Plataforma centrada en gamificación y refuerzo positivo. Sus simulaciones se adaptan al comportamiento del usuario para mejorar la participación y fortalecer el aprendizaje continuo.

4.2. Proofpoint

Solución consolidada que integra simulación de phishing con inteligencia de amenazas obtenida desde su ecosistema de seguridad de correo electrónico.

4.3. KnowBe4

Plataforma ampliamente conocida por su extensa biblioteca de contenidos, plantillas y campañas orientadas al entrenamiento masivo.

4.4. Cofense

Especializada en inteligencia obtenida a partir de reportes de usuarios y con fuerte orientación a respuesta a incidentes.

4.5. Phished

Utiliza inteligencia artificial y datos OSINT para crear campañas altamente personalizadas y dirigidas a perfiles específicos.

4.6. NINJIO

Destaca por su enfoque narrativo y audiovisual, buscando mejorar la recordación de conceptos de seguridad mediante storytelling.

4.7. Mimecast

Integra funciones de concientización dentro de su ecosistema de seguridad de correo, priorizando baja fricción operativa.

4.8. Infosec IQ

Ofrece rutas de aprendizaje estructuradas y diferenciadas según el perfil y nivel de conocimiento del usuario.

5. Tabla comparativa

Tabla 1: Comparativa técnica de plataformas de simulación de phishing

LightGray Plataforma	Enfoque	Capacidad de simulación	Integración / ética	Limitación principal
Hoxhunt	IA predictiva	Simulaciones altamente contextualizadas y dinámicas, adaptadas al comportamiento del usuario.	Refuerzo positivo y aprendizaje continuo.	Costo elevado por usuario.
Proofpoint	Inteligencia de amenazas	Simulaciones basadas en ataques reales neutralizados y tendencias observadas en correo corporativo.	Fuerte integración con su ecosistema de seguridad.	Curva de aprendizaje administrativa.
KnowBe4	Estadístico / masivo	Biblioteca extensa de plantillas, campañas y contenidos de concientización.	Implementación estandarizada y amplia adopción.	Parte del contenido puede sentirse genérico.
Cofense	Respuesta a incidentes	Enfoque orientado al reporte temprano y análisis de correos sospechosos.	Promueve participación activa del usuario.	Menor énfasis en contenido multimedia.
Phished	IA + OSINT	Simulaciones dirigidas y personalizadas según huella digital y contexto del usuario.	Alto realismo, aunque con cuestionamientos éticos.	Menor control manual fino.
NINJIO	Narrativo / audiovisual	Entrenamiento basado en historias y escenarios inspirados en incidentes reales.	Fomenta recordación mediante storytelling.	Estilo visual no siempre universal.
Mimecast	Integrado a correo	Simulaciones breves alineadas con protección de correo electrónico.	Baja fricción operativa.	Depende del ecosistema de la suite.
Infosec IQ	Educativo / estructurado	Rutas de aprendizaje y simulación diferenciadas por perfiles de usuario.	Buena alineación formativa.	Interfaz más rígida o académica.

6. Diagrama del flujo de una simulación de phishing

La Figura 1 representa de forma simplificada el flujo operativo de una campaña de simulación de phishing dentro de un programa de concientización. El proceso parte del diseño del escenario y concluye con la retroalimentación al usuario y la medición del riesgo humano.

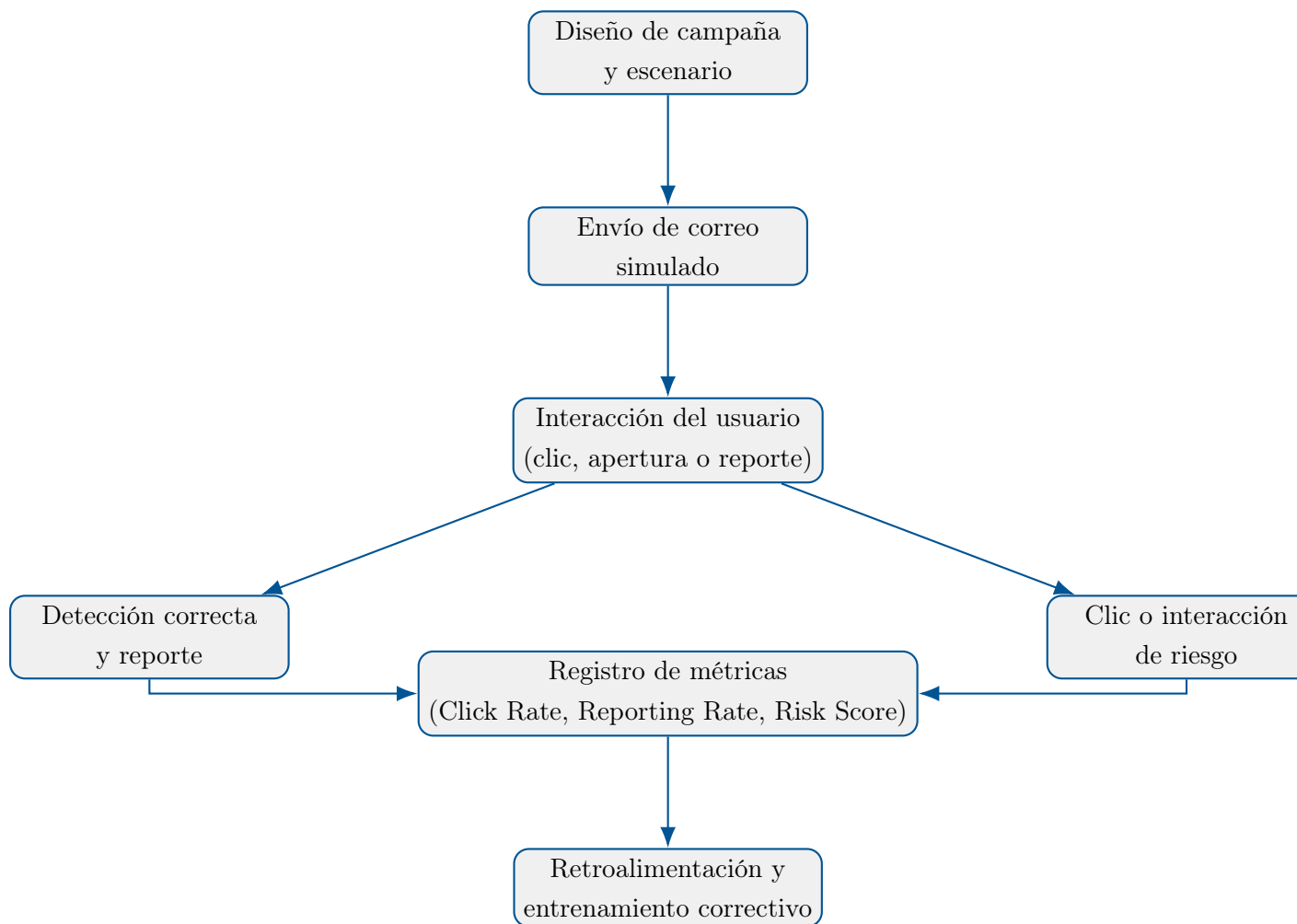


Figura 1: Flujo simplificado de una campaña de simulación de phishing.

7. Conclusiones

El análisis comparativo realizado demuestra que las plataformas de simulación de phishing no solo funcionan como herramientas de entrenamiento, sino también como mecanismos de medición del riesgo humano dentro de una organización. Su valor no radica únicamente en detectar quién hace clic, sino en comprender patrones de comportamiento, capacidad de reporte y nivel de madurez en la cultura de seguridad.

Asimismo, se observa una tendencia clara hacia enfoques menos punitivos y más formativos, donde el refuerzo positivo, la retroalimentación inmediata y la personalización de campañas resultan más efectivos que las estrategias basadas únicamente en castigo o exhibición del error.

En consecuencia, una campaña de ingeniería social éticamente diseñada debe equilibrar tres factores clave: realismo técnico, medición objetiva del comportamiento y respeto al usuario como parte integral de la defensa organizacional.

8. Referencias

- Gartner. (2022). *Magic Quadrant for Security Awareness Computer-Based Training*. Gartner Research.
- National Institute of Standards and Technology. (2023). *Building a Cybersecurity and Privacy Awareness and Training Program* (SP 800-50 Rev. 1).
- SANS Institute. (2023). *Security Awareness Report: Managing Human Risk*.
- Hoxhunt. (2024). *Automated Human Risk Management Platform*. Documentación técnica corporativa.
- Proofpoint. (2024). *Security Awareness Training & Phishing Simulation*. Documentación técnica corporativa.
- KnowBe4. (2024). *Security Awareness Training Platform Capabilities*. Documentación técnica corporativa.
- Cofense. (2024). *Crowdsourced Phishing Defense Solutions*. Documentación técnica corporativa.
- Phished. (2024). *AI-Driven Security Awareness Platform Overview*. Documentación técnica corporativa.
- NINJIO. (2024). *Story-Based Cybersecurity Awareness Training*. Documentación técnica corporativa.